You said:

codigo(1).py
Code

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Worked for 35s

Analyzed

Analyzed

ChatGPT said:

Análise de malware — `codigo(1).py`

Veredito: MALWARE

Alta confiança

O arquivo apresenta comportamentos claramente maliciosos: varredura de servidores, tentativas automatizadas de autenticação SSH, propagação para máquinas remotas, persistência no sistema e envio de informações a um serviço externo.

Categoria principal: worm de propagação via SSH, com força bruta ou tentativa automatizada de senhas e recursos de disseminação lateral.

A análise abaixo é estática: examinei o código-fonte sem executar o programa. O arquivo também passou pela verificação de sintaxe do Python.

1. Instalação de ferramentas e preparação do ambiente

O código verifica se está sendo executado como `root` e instala ferramentas como `masscan`, `curl`, `screen` e componentes do Python. Em seguida, cria diretórios e grava diversos scripts auxiliares no servidor. codigo.py

Por que isso é suspeito?

Instalar ferramentas de administração não é, por si só, malicioso. Entretanto, neste caso, elas são preparadas para automatizar a descoberta de servidores SSH acessíveis e tentar obter acesso a eles.

2. Varredura automatizada de servidores

O script auxiliar `run_scan.sh` executa continuamente uma rotina de descoberta de hosts nas portas **22 e 5522**, normalmente associadas ao SSH.

Ele utiliza o `masscan`, ajusta a taxa de varredura conforme os recursos disponíveis e repete o processo indefinidamente. codigo.py

O código define taxas de até 20.000 pacotes por segundo e permite varredura com múltiplas threads. codigo.py

Interpretação: trata-se de reconhecimento automatizado em escala, comportamento frequentemente observado em worms e ferramentas de comprometimento de servidores.

3. Tentativas de autenticação SSH com senhas predefinidas

A função `worker()` utiliza a biblioteca `paramiko` para conectar aos endereços descobertos, usando o usuário `root` por padrão e senhas especificadas pelo próprio programa. As conexões bem-sucedidas são gravadas em arquivos de saída. codigo.py codigo.py

Esse mecanismo apresenta características de **password spraying ou força bruta baseada em uma lista limitada de senhas**. A técnica tenta encontrar máquinas que aceitem credenciais conhecidas.

O uso de uma conta privilegiada e a automação de tentativas contra vários alvos tornam o comportamento especialmente preocupante.

4. Propagação para outras máquinas

Este é um dos indícios mais fortes de comportamento malicioso.

Após encontrar um servidor acessível, o código:

1. Lê o endereço IP e a porta encontrados pela varredura.
2. Tenta autenticar-se no servidor remoto com as senhas configuradas.
3. Transfere uma cópia do próprio programa, identificada como `bendi.py`, para o diretório `/tmp`.
4. Executa o arquivo transferido na máquina remota.
5. Tenta excluir a cópia temporária depois da execução. codigo.py

O código também instala um agente remoto de monitoramento por meio de um script baixado da internet. codigo.py

A instalação de um agente de monitoramento pode ter uso legítimo isoladamente. Porém, neste caso, ela está integrada a uma cadeia que descobre alvos, autentica-se com credenciais predefinidas e executa uma cópia do código em servidores remotos.

Interpretação: esse comportamento é compatível com um worm SSH, pois permite que o comprometimento de uma máquina seja usado para alcançar outras.

5. Persistência após reinicialização

O programa cria dois serviços do `systemd`:

- `scan-runner.service`, responsável por executar continuamente o processo de varredura.
- `file-monitor.service`, responsável por monitorar os arquivos de resultados e executar a rotina de propagação.

Ambos são configurados para executar como `root`, iniciar automaticamente e reiniciar caso o processo falhe. codigo.py

Depois, o script habilita e reinicia os serviços. Isso permite que as atividades continuem mesmo após reinicializações do servidor, enquanto os serviços permanecerem instalados e funcionais. codigo.py

Interpretação: é um mecanismo de persistência típico de malware instalado em servidores Linux.

6. Comunicação externa e envio de informações

O código configura a comunicação com uma API externa, utilizada para consultar e registrar alvos já processados. codigo.py

Também utiliza a API do Telegram para enviar relatórios de operação. Esses relatórios incluem o endereço do alvo, o resultado das ações e as credenciais utilizadas na conexão, incluindo a senha que funcionou quando o acesso é bem-sucedido. codigo.py codigo.py

O arquivo contém ainda um token de bot do Telegram e senhas configuradas diretamente no código. Não reproduzo esses valores aqui por serem segredos operacionais.

Risco adicional: essas credenciais devem ser consideradas expostas. Caso sejam reais, o token do bot precisa ser revogado e as senhas correspondentes devem ser alteradas.

7. Exclusão de arquivos e possível ocultação

Após configurar os serviços, o programa agenda a exclusão do próprio arquivo de origem. codigo.py

A rotina remota também exclui arquivos temporários e remove os arquivos que está processando. A limpeza de arquivos pode ter justificativas legítimas, mas, combinada com a persistência e a propagação, dificulta a análise posterior do comportamento e dos alvos tratados.

Não há evidência suficiente para afirmar que o código apaga logs do sistema de forma geral. Ainda assim, a exclusão da cópia original após a instalação é um indicador relevante de tentativa de reduzir vestígios.

8. Avaliação final dos comportamentos

Comportamento observado	Interpretação
Varredura contínua de endereços e portas SSH	Reconhecimento em escala
Tentativas de login com senhas predefinidas	Tentativa automatizada de obter acesso
Uso do usuário `root`	Busca por acesso privilegiado
Cópia e execução do próprio código em outros servidores	Propagação semelhante à de um worm
Serviços `systemd` com reinicialização automática	Persistência
Envio de credenciais em relatórios externos	Exposição de informações de autenticação
Exclusão do script original após a instalação	Redução de vestígios

Conclusão

Classificação definitiva: MALWARE, com alta confiança.

A categoria principal é **worm SSH com propagação automatizada por credenciais**. O arquivo reúne varredura de rede, tentativas de autenticação em servidores remotos, execução de uma cópia de si mesmo, persistência por serviços do sistema e envio externo de informações.

Não se trata apenas de um scanner de rede legítimo: a combinação entre obtenção de acesso e execução remota do próprio código demonstra capacidade de disseminação para outras máquinas.

Recomendação de segurança: não execute o arquivo. Se ele já foi executado em um servidor, isole a máquina da rede, investigue os dois serviços instalados, verifique os acessos SSH e revogue ou troque as credenciais expostas.

Também posso criar um ↪ diagrama visual da propagação.

‹/›

You said:

Qual é a categoria principal deste malware?

ChatGPT said:

A categoria principal deste malware é **Worm (verme de rede) com propagação via SSH**, utilizando tentativas automatizadas de autenticação com senhas predefinidas.

O malware identifica servidores SSH acessíveis, tenta obter acesso como `root` e copia e executa seu próprio código nas máquinas comprometidas, permitindo a propagação para outros servidores. codigo.py